

C2フレームワーク ビーコン特性&検知チートシート

主要なC2フレームワーク（Cobalt Strike, Sliver, Havoc）が使用する各プロトコル（HTTP/S, DNS, SMB）のビーコン通信の内部特性、検出手法、およびSIEM（Splunk等）/ Arkime（PCAP）での検索用クエリをまとめた実務用リファレンスです。

1. 主要C2フレームワークのアーキテクチャ概要

1-1. Cobalt Strike (Malleable C2 Profile)

通信の見た目（HTTPヘッダー、URL構造、Jitter、パケットサイズ、インジェクション先）を自在に偽装できる「Malleable C2 Profile」を持つ。デフォルトのままであればシグネチャ検知しやすいが、カスタマイズされるとネットワークのみでの検知が困難になるため、JA3/JA4フィンガープリントや定時性解析が極めて重要となる。

1-2. Sliver (Golangベースの高度C2)

Go言語で作成されており、バイナリサイズが大きい。HTTP/S以外に、高機能なDNSトンネリング、mTLS（相互TLS）、WireGuardプロトコルを標準搭載。ビーコンの通信間隔を完全にランダム化する高度なJitter（デフォルトで大きな揺らぎ）が特徴。

1-3. Havoc (モダンなC++ベースC2)

「Demon」と呼ばれる洗練された高度なエージェントを使用。スリープ時の暗号化、間接システムコール（Indirect Syscalls）によるEDR回避機能を持ち、HTTP/S通信ではデフォルトで高密度かつ特有のJSON構造（暗号化されたペイロード）をやり取りする。

2. プロトコル別ビーコン特性と検知・検索ロジック

2-1. HTTP / HTTPS ビーコン

最も広く使われるC2プロトコル。一定時間ごとに外部のC2サーバーに接続（GETで命令確認、POSTで結果送信）する。

フレームワーク別の特徴	Cobalt Strike デフォルトURL (/activity, /submit.php等)。CookieやUAがプロファイルで偽装される。 Sliver ランダムな文字列のURL (拡張子が .html, .js, .php に見えるよう偽装)。 Havoc デフォルトでユーザーエージェントに Mozilla/5.0 (Windows NT 10.0; Win64; x64) ... を使用するが、POSTボディが完全に暗号化されたバイナリデータ (平文テキストを含まない) となる。
検知の着眼点	① 定時性 (低Jitter) の抽出: 通信間隔の標準偏差 (stdev) が極端に少ない接続。 ② JA3/JA4 フィンガープリント: Windows標準のブラウザやアプリ (Edge, Windows Update等) とは異なる不審なTLSハンドシェイク特性。 ③ HTTPヘッダーの不整合: Content-Typeと実際の中身 (バイナリ等) の不一致。
Splunk / SIEM 検索クエリ	<pre># Zeek http.log から定時接続 (ビーコニング) の傾向があるペアを抽出 index=zeek sourcetype=zeek_http streamstats time_window=2h current=f last(_time) as prev_time by src_ip, dest_ip eval time_diff = _time - prev_time stats count, avg(time_diff) as avg_interval, stdev(time_diff) as jitter by src_ip, dest_ip, user_agent where count > 30 AND jitter < 10 sort + jitter</pre>
Arkime (PCAP) 検索クエリ	<pre># SSL/TLS通信において、通常端末が使わないJA3フィンガープリントのセッションを検索 protocols == tls && tls.ja3 == ["b1e84...[既知のC2ハッシュ]", "7aa2d..."] # または、特定の短いないし一定パケットサイズのHTTP POSTの連続 protocols == http && http.method == "POST" && bytes < 2000</pre>

2-2. DNS ビーコン (DNS トンネリング)

ファイアウォールでWeb (80/443) が厳しく制限されている環境において、組織内のDNSキャッシュサーバーを経由して外部と通信するステルス手法。サブドメイン部分に暗号化した命令を埋め込む。

フレームワーク別の特徴	Cobalt Strike mode dns（Aレコードを使用）またはmode dns-txt（TXTレコードを悪用し大きなデータを返す）。cdn. や www6. のような偽装接頭辞を多用。 Sliver 高機能なDNS C2。非常に長大なランダム文字列のサブドメイン（例: v3.a1b2c3d4e5f6...example.com）を生成。TXT、A、AAAAレコードをランダムに組み合わせて検知を回避する。
検知の着眼点	① DNSクエリの文字長とエントロピー: サブドメインの文字列が異常に長く、ランダム性が高い。 ② ユニークサブドメイン数（dc）の爆発: 同一親ドメイン（例: attacker.com）に対して、数千から数万件の異なるユニークなサブドメインへの解決試行が発生する。 ③ NXDOMAINエラーの大量発生: C2との同期ズレや探索時に存在しないドメインへの解決失敗が頻発。
Splunk / SIEM 検索クエリ	<pre># 同一の親ドメイン（登録ドメイン）に対して膨大なユニークサブドメインを要求しているホストを特定 index=zeek sourcetype=zeek_dns eval query_len = len(query) where query_len > 40 stats count, dc(query) as unique_subdomains, avg(query_len) as avg_len by src_ip, query_zone where unique_subdomains > 100 sort - unique_subdomains</pre>
Arkime (PCAP) 検索クエリ	<pre># 大量のデータを運ぶために悪用されるTXT、CNAME、AAAAレコードのDNS通信を抽出 protocols == dns && (dns.qt == "TXT" dns.qt == "CNAME") && bytes > 1000 # ※ArkimeのSPIビューで「dns.query」の文字列パターンを目視確認し、Base32/Base64らしき羅列がないかチェック</pre>

2-3. SMB / Named Pipe (名前付きパイプ) ビーコン

インターネットへ直接出られない内部サーバーに対し、すでに侵入済みの「踏み台端末」からローカルネットワーク（ポート445）経由で命令をリレー（水平展開）させるために使用される。

フレームワーク別の特徴	Cobalt Strike 横展開時に \\Host\\pipe\\msagent_xxxx（デフォルト値。xxxxはランダム）という名前付きパイプを作成して通信。 Sliver 名前付きパイプを利用した通信をサポート。パイプ名はランダムに偽装可能だが、特定のRPCバインディングや一連の認証失敗・成功のパターンがWindowsイベントに残る。
検知の着眼点	① 不審なパイプ名の監視: システム内で通常使われない名前付きパイプの作成（Sysmon EID 17/18）。 ② IPC\$ への異常なリモート接続: Windows標準セキュリティログ（EID 5140, 5145）における、管理共有（C\$, IPC\$）への不自然なアクセス履歴。
Splunk / SIEM 検索クエリ	<pre># Sysmon EventCode 17（名前付きパイプの作成）から、既知のC2デフォルトパターン（msagent等）や不審なパイプを検知 index=sysmon EventCode=17 eval PipeName = lower(PipeName) where like(PipeName, "%msagent%") OR like(PipeName, "%sliver%") OR NOT (like(PipeName, "%lsass%") OR like(PipeName, "%samr%") OR like(PipeName, "%wkssvc%")) stats count by host, Image, PipeName</pre>
Arkime (PCAP) 検索クエリ	<pre># 同一セグメント（内部）間でのポート445（SMB）における、定常的ではない大容量あるいは持続的なセッション protocols == smb && port == 445 && ip.src == 10.0.0.0/8 && ip.dst == 10.0.0.0/8 ※Arkimeの「SMB/RPC」デコード機能で、やり取りされている「Named Pipeの名前」を特定・抽出する。</pre>